QUICK GUIDE · BANKS IN QATAR

AI Security Risk Add-on: quick guide

Version 1.0 - November 2026 · Built with AI assistance; every requirement and citation checked against the QCB and NCSA source texts. Free to use and adapt; please credit the source.

> Advisory. Suggestions to help banks add AI security risk management and the national requirements to their existing ISO/IEC 27001, ISO/IEC 27005 and ISO 31000 process. The official texts prevail. Each bank remains responsible for its own compliance.

Three layers: 1. Essentials (sheet 0) - start here; 2. Working sheets (1-8, 10) - content for the existing inventory, register, SoA and calendar, with fields and calendar rows tagged Essential or Recommended; 3. Reference (5B, 9A, 9B, 9C) - full requirement detail for evidence and audit, where status is recorded. Every REQUIRED and Must row applies wherever it sits.

The 13 essentials

ID	Action	Source
E01	Keep an AI Register of every AI system, with the QCB fields and the high-risk classification	AI Guideline 10.1, 10.7, 9.6-9.7
E02	Disclose to QCB the high-risk criteria and a high-level risk and impact assessment, and the full AI Register every year and on request	AI Guideline 10.2-10.3, 10.6
E03	Obtain QCB approval before launching AI as a Provider, a material change, a high-risk AI agreement, a cloud arrangement or a material cloud arrangement	AI Guideline 11.1-11.2; Cloud Regulation 13.4, 21.5
E04	Give every AI system a human oversight protocol; for fully autonomous high-risk AI, get QCB approval before launch	AI Guideline 13.1, 13.6
E05	Protect AI models: examine the attack surface before deployment; protect against integrity attacks, query attacks and prompt injection	AI Guideline 17.4-17.7
E06	Process PII and financial information in Qatar for cloud AI; get QCB approval for any foreign storage or transfer	Cloud Regulation 21.4; DHP 15.1
E07	Do a PIA for new or changed sensitive AI processing; give customers a route to human review of AI decisions	DHP 10.4; AI Guideline 21

ID	Action	Source
E08	Classify AI assets under the National Data Classification Policy and apply NIA baseline (*) controls for assets rated 1 or above	NIA v2.1 2.3 a-c
E09	Add AI risks to the Information Security Risk Register and map ratings to the national bands	EISRMF
E10	Submit the risk register, treatment plan and annual attestation to NCSA	EISRMF; NISRMF
E11	Report High and Severe risks to NCSA out of band: immediately, with a detailed report within 48 hours	EISRMF
E12	Report incidents: critical incidents to QCB and the relevant governmental authorities within 1 hour (8.2.10) and to NCSA within 2 hours (IM 8; whether 8.2.10 covers NCSA is open); QCB Hotline: cyber or technology High 1 hour, Medium 4 hours, other operational High 4 hours; final report within 3 days of resolution; monthly report	NIA v2.1 IM 8; QCB Technology Risks circular 8.2.10; QCB Incident Reporting Guideline 6.2-6.3
E13	Report data breaches as incidents to QCB, and also to NCSA and the Ministry of Interior	DHP 16.1-16.3

Rule: an action is an essential only if its source uses mandatory wording (QCB 'must', NCSA REQUIRED, NIA baseline). E12 also includes the 'should' timeframes of Incident Reporting Guideline 6.2.

Then, in the working sheets

Add the AI asset types (1) and rate AI systems (5A). Select the scenarios that apply (4), rate them on the bank's own scale and map ratings to the national bands (9B). Mark applicable AI controls (5) in the SoA. Add missing fields (8), starting with those tagged Essential. Set approvers and risk appetite (8A); log accepted risks (8B). Enter last submission dates (10); start indicators (6) and triggers (7).

Two reporting lines

To	What	Source
QCB	Critical incidents within 1 hour (Technology Risks circular 8.2.10); incidents by QCB priority (cyber or technology High 1 hour, Medium 4 hours; other High 4 hours; final report 3 days after resolution, monthly report); AI Register yearly; approvals before launch or signing	Technology Risks circular 8.2.10; Incident Reporting Guideline 6.2-6.3; AI Guideline 10.6, 11; Cloud Regulation 13.4, 21.5
NCSA	Critical incidents within 2 hours (1 hour suggested until confirmed); High and Severe risks out of band (48-hour report); register, treatment plan, attestation	NIA v2.1 IM 8; Technology Risks circular 8.2.10; EISRMF; NISRMF

When X happens: what to do and where

Ten everyday events. Numbers are sheets, letters are columns. Sheet 7 lists all inputs, where to record each one and the reassessment days (set by the bank). Deadlines as stated in the sources cited; open points are in the References sheet.

When	What to do, and by when	Where to record it	Who approves
New AI system or use case (T09)	Assess before go-live; check whether QCB approval is needed (E03)	5A: new row, ratings (D-F); 4: scenarios, owner, ratings; 9A: approval rows	Band approver (8A); QCB if required
Model, prompt, tool or data change (T09)	Before go-live: re-test (C12); if a Provider, check for a material change needing QCB approval (E03)	4: rating (N), status (T); 5: C12 evidence	Risk owner; band approver (8A)
Vendor adds an AI feature (T10)	Before use; check for a material modification needing QCB approval (AI Guideline 11.1, 14.3)	5A if new; 4: third-party scenarios; 8: provider fields, supplier assessment date	Risk owner
Critical AI incident (T01)	QCB within 1 hour (8.2.10; Hotline if High); NCSA within 2 hours (IM 8; 1 hour suggested until confirmed); final report within 3 days of resolution (Incident Reporting Guideline 6.3)	10: report rows, date sent (E); 8: times reported; 4: re-rate scenarios	Incident process
Incident at an AI provider (T17)	Report to QCB (Incident Reporting Guideline 6.3); priority as for T01 or T02	As for T01; 4: third-party scenarios	Incident process
Test or red-team finding (T04, T05)	Treat as a vulnerability; track to closure	4: rating (N), treatment (S), status (T), target date (Y)	Band approver (8A) if accepted
KRI turns red (T06)	Escalate to the risk owner; reassess the linked scenarios	6: value (K), date (L); 4: scenarios in 6, column J	Risk owner
Risk above appetite (4, W)	Treat, or get acceptance from the approver in 8A; if High or Severe (4, P), notify NCSA out of band, report within 48 hours (EISRMF)	4: treatment (S), target date (Y); 8B: new row; 10: out-of-band row (E)	Risk owner; band approver (8A)
Acceptance due or expired (8B, N)	Review before the review date; renew, change the treatment or close	8B: new row, dates (E, J); review date (K) calculated	Risk owner; band approver (8A)
Deliverable due (10, G)	Prepare and submit (for example AI Register, NCSA risk register, monthly incident report)	10: last submitted (E); next due (F) calculated	As in the sheet 10 notes